loads ne sont pas executés ils ne sont donc pas persistent, les attaques n'affectent donc pas les utilisateurs visitant la page mais seulement le/les utilisateurs cib par nos attaques. Pour une requete GET on peux envoyer le lien piégé à la victi si elle clique le code s'éxécutera... Si le payload est envoyé dans le body de requete avec POST le processus est un peu plus complexe et va utiliser une pay- tuxee pour forcer le navigateur de la victim à effectuer cette requete malveillan a son insu (CSRF)

XSS_Basée Sur Le DOM:

Le dernier type d'XSS est celle basée sur le DOM, c'est une XSS non persi ente et exécuté et traité entierement coté client, contrairement aux XSS-Reflé qui envoi les données d'entrées au serveur backend via des requetes HTTP. L'XSS Basée sur le dom se produit lorsque JavaScript est utilisé pour modifier source de la page via le Document Objet Model (DOM)

- Pour bien comprendre l'XSS_Basé sur le DOM on doit comprendre le c cept de Source et de Collecteur de l'objet affiché sur la page.

La Source: c'est l'objet JS qui prend l'entrée de l'utilisateur, il peux s'ag de n'importe quel paramètre d'entrée comme un parametre URL ou un ch de saisie.

Le Collecteur: la fonction qui ecrit l'entrée utilisateur dans un objet du DO sur la page. Si la fonction collecteur n'assainit pas correctement l'entrée de l tilisateur elle sera vulnérable à une XSS.
Les fonctions JS couramment utilisés pour écrire dans ce les objets du DOM, s (document.write(), DOM.innerHTML, DOM.outerHTML). De plus certaines fonc ons de la bibliothèques JQuery qui écrivent dans les objets du DOM sont (add(after(), append())

Encore une fois il faux étudier le traitement des entrés et adaptés nos payl ds... (Ex: les balises <script> ne sont pas autorisés dans la fonction innerHTML m on a bien d'autres payloads sans ces balises...)

Découverte Des Failles XSS:

On a une part la detection automatique, presque tout les scanners de vul rabilités (Nessus BurpPro ZAP) on diverses scripts permettant une potentielle tection d'XSS. Les scanners effectuent généralement une analyse passive (an lyse du code source) et une analyse active (envoi de payloads)
Parmi les bon scripts open-source pour la detection d'XSS on peux noter XSS Str ou encore Brute XSS ou XSSer.

```
Agentpathogen@parrot ~$ python3 xsstrike.py -u "https://url_vulnérable.cu
```

On peu aussi rechercher les XSS manuellement ce qui va demander des compé ces avancées en revue de code.
Nous avons tj nos bons alliés Payload All The Things Payload-Box
Et notre capacité a programmer pour automatiser...
Mais la methode la plus fiable pour detecter ces vulns c'est la revue du code man elle, si on comprend comment la requete est traité jusqu'au serveur on peux plu facilement en detourner l'usage..

Les Attaques XSS Le Defacage (1):

C'est bien gentil de decouvrir une XSS il faut maintenant l'exploiter... Une XSS stocker peux mener à un Defacage (changement) d'apparence d'un site